

pfSense: Adding Firewall Rules to Filter Services

pfSense is an open source firewall, router and UTM (unified threat management) distribution based on FreeBSD. This is the third article in the series on pfSense, and it helps readers in designing and configuring firewall rules as per their requirements.

The first two articles in this series described the basic pfSense set-up, installation and configuration of the Squid Proxy server, SquidGuard proxy filter, and configuration of dual WAN failover. This article starts off from the point when pfSense has been configured, at the end of the second article. It then continues to configure the firewall to filter services – to allow internal computer systems to access required websites/IP addresses located in the Internet using permitted services by configuring firewall rules. Please refer to the earlier articles to establish a firewall in dual WAN failover.

What is services filtering?

Many people view a firewall as a device to block access to undesirable websites, which is partially true. Emphasis must also be given to blocking requests from the internal network towards the Internet or external network, using undesirable services. This control is still not seen in many implementations.

For example, a firewall not configured to block undesirable services will not block malicious software such as viruses, worms, spyware, etc, from sending emails out using email services such as SMTP or from sending outgoing traffic using non-standard ports. This type of traffic could also lead to blacklisting of your static IP address.

It is crucial that services blocking is enabled along with website filtering to ensure correct firewall configuration.

The concept of the port

To explain it in simple terms, imagine a server connected to a single client by a crossover cable. This server is running three different services – HTTP, SSH and FTP. The client system is trying to access these services simultaneously using only one physical cable. This gives rise to two questions:

1. How does the server differentiate between the requests received from different clients? How does it determine which packet is for which service?
2. How does the client differentiate between the replies received from the server? How does it determine which packet is received as reply to which request sent earlier?



The answer lies in the concept of a port – different services run on different ports.

The HTTP service runs on Port 80, SSH on Port 22, FTP on Port 21, and so on. In all, there are 65,535 ports.

While sending requests to the server, the client sends the IP address of the server as part of the IP header and the port number for the service as part of the TCP header. In addition, the client also sends the self IP address as the source IP address, and adds a randomly generated source port as the source port number.

While replying, the server reverses the source and the destination IP addresses so that the packet reaches the client, and also reverses the source/destination port numbers for the client to understand which packet belongs to which service request.

The handshake remains the same for multiple clients and servers. The source and destination IP addresses identify the client and the server, while the source and destination ports identify the service request and the reply. See Figure 1 for quick understanding.

In firewall parlance, the terms 'ports' and 'services' are often used interchangeably, and mean the same thing.

Please note that this explanation is only to simplify the concept of ports. You can refer to a more detailed explanation of the TCP/IP handshake on Wikipedia.

The firewall configuration scenario

Let us consider a typical requirement for a company, which would be to allow access depending on the work profile of employees. Let's assume that there are three groups – admins, engineers and accountants with various access requirements.

The first step is to prepare a basic Access Control List (ACL), a sample of which is shown in Table 1. We will use this ACL to configure pfSense for this article.

Discussions should be held with all computer users to try and find all the services and websites being used by them, in order to create ACLs. Employees should be asked whether they use a specific website frequently or not. For instance, during such discussions, a website being used once in three months might get identified, which runs on a non-standard port 8080. In the example given in Table 1, it could belong to the Pune Municipal Corporation local body tax division.